ENTERPRISE SECURITY TRAINING

Phishing Awareness: Don't Take The Bait

From fundamentals to advanced threat detection. A comprehensive guide to identifying, avoiding, and reporting social engineering attacks.

TARGET AUDIENCE
Beginners to Advanced

MODULE DURATION
15–20 Minutes

01. THREAT OVERVIEW

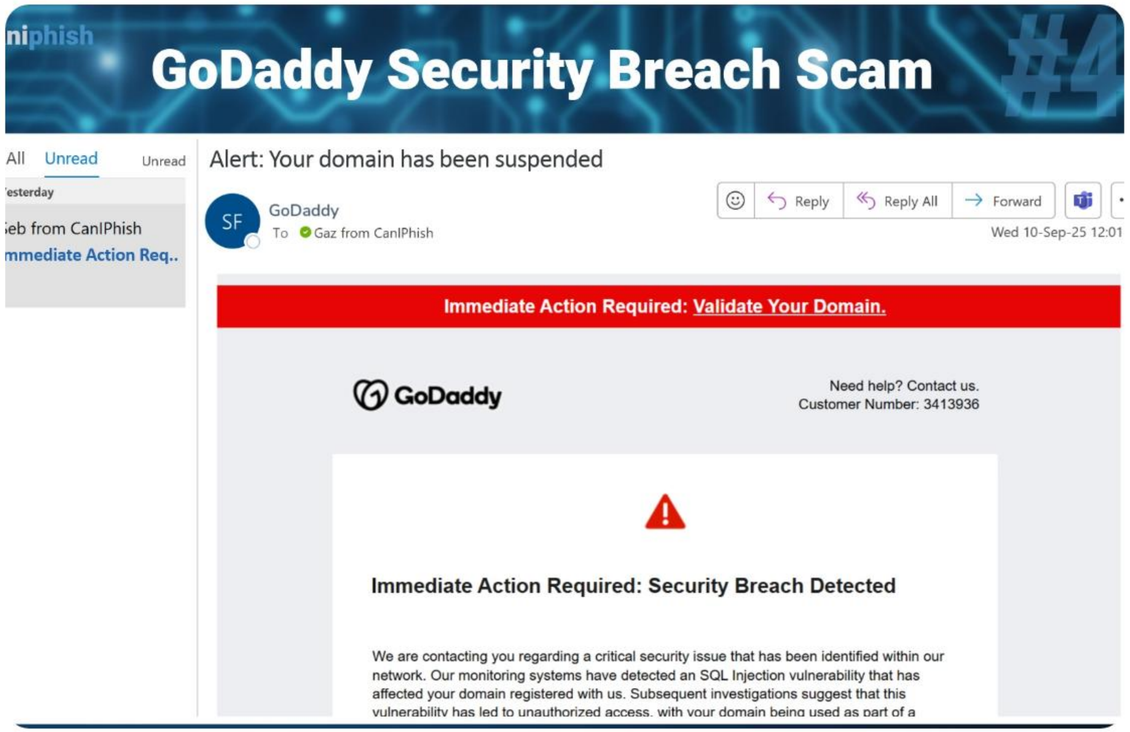
What is Phishing & How It Works

Core Definition

A deceptive technique where attackers impersonate trusted entities to manipulate victims into revealing confidential information or installing malware.

The 4-Step Attack Lifecycle

1. Crafting fraudulent message with urgent trigger
2. Bypassing basic email security filters
3. Target clicks link or opens malicious attachment
4. Credential theft, malware installation, or wire fraud



02. ATTACK VECTORS

6 Primary Types of Phishing

Email Phishing

Mass spam emails pretending to be banks, SaaS vendors, or services.

Spear Phishing

Highly targeted attacks customized for specific individuals or teams.

Whaling

Spear phishing explicitly targeting C-level executives and VIPs.

Smishing

SMS-based phishing using urgent delivery alerts or account locks.

Vishing

Voice call scams spoofing IT support, banks, or government agents.

Clone Phishing

Replicating a legitimate past email but replacing links with malicious URLs.

03. DETECTION

7 Red Flags of a Phishing Email

1. Urgent or Threatening Language
Demands immediate action ("Account suspended in 2 hours") to cause panic.

2. Generic Greetings
Uses "Dear Customer" or "Valued Employee" instead of your actual name.

3. Suspicious Sender Domain
Email address doesn't match the company (e.g., support@paypa1-security.com).

4. Spelling & Grammar Errors
Awkward sentence structures, bad formatting, or odd capitalization.

5. Unexpected Attachments & Unmatched Links
Unsolicited .zip, .exe, or .html files, and links pointing to mismatched URLs.

04. DEEP DIVE

Anatomy of a Phishing Email

FROM: IT Helpdesk

RED FLAG: Spoofed domain (m1crosoft)

SUBJECT: URGENT: Password Expiring in 1 HOUR - Action Required

RED FLAG: Artificial urgency & threat

Dear User,

Your corporate account requires immediate password validation. Failure to update will result in termination of network access.

UPDATE PASSWORD NOW

Hover reveals real link: http://192.168.1.45/login.php?steal=credentials

05. WEB SAFETY

How to Recognize Fake Websites

Lookalike Domains (Typosquatting)

Attackers register domains that look identical to genuine sites, using character swaps like 'rn' instead of 'm' or substituting '1' for 'l'.

HTTP vs HTTPS Fallacy

HTTPS and a padlock icon mean the connection is encrypted—it does NOT mean the site is legitimate. Over 80% of phishing sites now use HTTPS.

Poor Layout & Broken Assets

Look for low-resolution logos, broken footers, dead internal links, or mismatched font rendering across the webpage.

Aggressive Data Requests

Legitimate portals won't prompt for full Social Security numbers, PINs, or recovery codes immediately upon landing.

06. PSYCHOLOGY

Social Engineering Triggers

Fear

Threats of account suspension, legal action, or financial loss.

"PAY NOW OR ACCOUNT CLOSED"

Urgency

Short deadlines forcing victims to bypass logical analysis.

"ACTION REQUIRED IN 15 MINS"

Curiosity

Intriguing notices about secret bonuses, packages, or news.

"VIEW CONFIDENTIAL SALARY LIST"

Authority

Impersonating executives, IT leads, or law enforcement officers.

"CEO REQUEST: SEND GIFT CARDS"

Greed

Unrealistic financial rewards, prizes, or investment opportunities.

"YOU WON $5,000 CRYPTO BONUS"

07. CASE STUDIES

Famous Real-World Attacks

2017 OUTBREAK

Google Docs Worm

Mass OAuth exploit tricked users into granting permission to a malicious web app named 'Google Docs', bypassing passwords entirely.

RECURRING THREAT

PayPal Account Lock Scams

Millions of emails warning of unauthorized charges led victims to pixel-perfect cloned sites stealing credit cards and SSNs.

ENTERPRISE TARGET

Office 365 Credential Harvest

Fake voicemail notifications hosting malicious links that captured corporate logins, leading to internal BEC attacks.

08. IMPACT ANALYSIS

Consequences of Falling For Phishing



Financial Losses & Fraud

Direct wire fraud, stolen bank accounts, and expensive ransomware recovery costs.

Data Breaches & Leakage

Exposing sensitive customer data, employee records, and trade secrets to dark web sales.

Reputational Damage

Loss of customer trust, negative media coverage, and regulatory compliance fines.

09. DEFENSE STRATEGY

Golden Rules 1 – 5 to Stay Safe

01 **Verify Senders Out-of-Band**
If receiving payment requests, call the sender using a known internal directory phone number.

02 **Hover Before You Click**
Inspect hyperlinked text by hovering your mouse pointer to review the actual destination domain.

03 **Enforce Multi-Factor Authentication (MFA)**
Use authenticator apps or security keys so stolen passwords alone cannot grant account access.

04 **Never Download Unsolicited Attachments**
Do not open or enable macros on unexpected files (.zip, .pdf, .xlsm, .doc) from external senders.

05 **Use the Phishing Report Button**
Report suspicious emails immediately to your Security Operations Center (SOC) via Outlook/Gmail plug-ins.

10. DEFENSE STRATEGY

Golden Rules 6 – 10 to Stay Safe

06 **Keep Browsers and Operating Systems Updated**
Patch security vulnerabilities regularly to block drive-by exploits and browser vulnerabilities.

07 **Beware of Public Wi-Fi Networks**
Avoid accessing confidential company resources on unsecured public Wi-Fi without an active corporate VPN.

08 **Never Share Credentials over Unencrypted Channels**
IT personnel will never ask for your password via phone call, email, or instant message.

09 **Bookmark Frequently Used Portals**
Navigate to critical portals using saved bookmarks rather than clicking links embedded inside emails.

10 **Limit Public Information Exposure**
Minimize revealing specific team roles, software tools, or operational details on social media sites.

11. INCIDENT RESPONSE

What To Do If You Clicked A Link

1. Disconnect Instantly

Unplug ethernet cable or disable Wi-Fi immediately to cut malware communication channels.

2. Report to Security Team

Notify IT/SOC hotline right away. Fast reporting minimizes lateral damage across network.

3. Change Compromised Passwords

Reset credentials from an uninfected device. Revoke active session tokens if possible.

4. Scan & Monitor Accounts

Run endpoint antivirus scans and inspect accounts for unauthorized rules or logins.



12. ASSESSMENT

Interactive Quiz: Questions 1 & 2

Q1: You receive an email from "IT" asking you to click a link to verify your password due to a server migration. What should you do?

A. Click the link immediately to prevent losing access

B. Report the email to security & verify via IT hotline

Q2: What is the main difference between general phishing and spear phishing?

A. Spear phishing only happens via telephone calls

B. Spear phishing is personalized targeting a specific victim

13. ASSESSMENT

Interactive Quiz: Questions 3 & 4

Q3: Does a padlock icon (HTTPS) in the browser address bar guarantee a website is safe?

A. Yes, HTTPS means the site is verified and legitimate

B. No, phishing sites also use HTTPS encryption

Q4: What is "smishing"?

A. Phishing conducted via SMS text messages

B. Phishing carried out over corporate Slack or Teams

14. ASSESSMENT & SUMMARY

Quiz Question 5 & Wrap-Up

Q5: What is your immediate first step if you accidentally enter credentials on a phishing page?

A. Wait until end of day to see if anything happens

B. Disconnect device & notify IT/SOC immediately

Stay Vigilant. Think Before You Click.

Report all suspicious activity to security@company.com

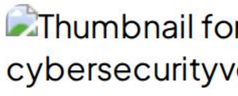


Image Sources



https://d3p8e1mvy30w84.cloudfront.net/assets/images/articles/simulated-phishing-emails/godaddy.webp

Source: caniphish.com



https://cybersecurityventures.com/wp-content/uploads/2021/03/system-hacked.jpg

Source: cybersecurityventures.com



https://www.cyber72.com/wp-content/uploads/2023/07/81J9wwm9WxL._AC_SL1500_-1024×803.jpg

Source: cyber72.com